

Command injection is possible via activation script #2768

🔒 Closed



y5c4l3 opened on Sep 23, 2024 · edited by y5c4l3 Edits ▾ Contributor ⋮

Issue

This issue was originally reported to Tidelift, with disclosure negotiated with the maintainer.

The activation script in `virtualenv` is command injectable via a crafted path:

```
envname="';uname -a;':"
mkdir "$envname"
cd "$envname"
virtualenv .
. ./bin/activate
```

```
Linux archlinux 6.10.6-arch1-1 #1 SMP PREEMPT_DYNAMIC Mon, 19 Aug 2024 17:02:39
```

The execution path is low-risk since users clearly know what they are doing. However, it makes *downstream attack vectors* possible. More details on possible exploits of a famous downstream were disclosed to the maintainers of that project and `virtualenv`.

Environment

- OS: Linux

1 2

📄 **y5c4l3** added bug on Sep 23, 2024

🔗 **y5c4l3** added 3 commits that reference this issue on Sep 27, 2024

- | | |
|---|------------------|
| Quote template strings in activation script ... | Verified 619c592 |
| Quote template strings in activation script ... | Verified c8171d1 |
| Quote template strings in activation script ... | Verified fed2947 |

🔗 **y5c4l3** mentioned this on Sep 27, 2024

🔗 Fix #2768: Quote template strings in activation scripts #2771

ΛΦ

y5c4l3 added a commit that references this issue [on Sep 27, 2024](#)

Quote template strings in activation script ...

Verified 63cb3a8

ΛΦ

y5c4l3 mentioned this [on Sep 27, 2024](#)

✓ [\[CVE-2024-9287\]](#) [venv](#) [activation scripts do not quote strings properly python/cpython#124651](#)

gaborbernat closed this as [completed](#) in [86ddded](#) [on Sep 28, 2024](#)

hswong3i added a commit that references this issue [on Sep 28, 2024](#)

Fix [pypa#2768](#): Quote template strings in activation scripts ([pypa#277](#))

i

Verified 86ddded

musicinmybrain mentioned this [on Nov 26, 2024](#)

✓ [Please comment on CVE-2024-53899 and virtualenv activation scripts astral-sh/uv#9424](#)

arcivanov mentioned this [on Jan 15, 2025](#)

✓ [\(virtualenv\) CVE-2024-53899 - severity critical - used version of virtualenv allows remote code execution pybuilder/pybuilder#920](#)

Sgitarior mentioned this [on May 20, 2025](#)

[SWATCH-3399: Bump to Python 3.9 to fix CVE PYSEC-2024-187 RedHatInsights/rhsm-subscriptions-egress#89](#)

Sign up for free to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

bug

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

No branches or pull requests

